Note de montage du laboratoire — Opération Gryphon

Document de reproductibilité du lab. Toutes les étapes ci-dessous permettent de reconstruire le contrôleur de domaine `meridian.local` à l'identique.

- **Palier** : Couche 1, option « expérience de bureau sur le contrôleur de domaine » (DC unique administré en interface graphique).
- **Cible** : Windows Server 2025 Datacenter, image officielle, hébergée sur une VM cloud GCP.
- **Attaquant** : Kali Linux local.
- **Accès** : restreint par pare-feu à la seule IP publique de l'attaquant.

> Aucun secret réel (mot de passe, hash) ne doit être commité. Les valeurs ci-dessous sont celles du lab pédagogique.

---

1. Architecture

Hôte	Rôle	Détail
DC01	Contrôleur de domaine	Windows Server 2025 Datacenter, VM GCP `e2-medium`, zone `europe-west1-b`
Kali	Attaquant	Poste local (WSL), outils offensifs

---

2. Déploiement de la VM (GCP)

VM Compute Engine, image publique Windows Server 2025 Datacenter, disque 50 Go, balise réseau `gryphon-rdp`.

Mot de passe administrateur Windows généré via :

```bash
gcloud compute reset-windows-password dc01 --zone=europe-west1-b --user=gryphon
```

Règles de pare-feu (limitées à l'IP de l'attaquant)

```bash
# Acces principal : RDP + ports AD
gcloud compute firewall-rules create gryphon-rdp \
  --network=default --direction=INGRESS --action=ALLOW \
  --rules=tcp:3389,tcp:445,tcp:389,tcp:88,tcp:135,tcp:636,tcp:5985 \
  --source-ranges=<IP_ATTAQUANT>/32 --target-tags=gryphon-rdp

# Plage RPC dynamique (necessaire au DCSync via DRSUAPI)
gcloud compute firewall-rules create gryphon-rpc \
  --network=default --direction=INGRESS --action=ALLOW \
  --rules=tcp:49152-65535 \
  --source-ranges=<IP_ATTAQUANT>/32 --target-tags=gryphon-rdp

# DNS (necessaire a la collecte BloodHound)
gcloud compute firewall-rules create gryphon-dns \
  --network=default --direction=INGRESS --action=ALLOW \
  --rules=tcp:53,udp:53 \
  --source-ranges=<IP_ATTAQUANT>/32 --target-tags=gryphon-rdp
```

> Remplacer `<IP_ATTAQUANT>` par l'IP publique de Kali (`curl ifconfig.me`). Si elle change, mettre à jour les `--source-ranges`.

---

3. Promotion du domaine

À exécuter sur le DC (PowerShell admin), après avoir défini un mot de passe conforme pour le compte `Administrator`.

```powershell
# 1. Role AD DS
Install-WindowsFeature AD-Domain-Services -IncludeManagementTools

# 2. Promotion en foret meridian.local (reboot automatique)
Import-Module ADDSDeployment
Install-ADDSForest `
  -DomainName "meridian.local" `
  -DomainNetbiosName "MERIDIAN" `
  -ForestMode "WinThreshold" -DomainMode "WinThreshold" `
  -InstallDns:$true `
  -SafeModeAdministratorPassword (ConvertTo-SecureString "DsrmP@ss2026!" -AsPlainText
  -Force:$true
```

> Sur GCP, ne pas forcer d'IP statique ni de DNS manuel avant la promotion : le réseau est géré par Google et `Install-ADDSForest` configure le DNS correctement.

---

4. Structure AD, comptes et chemins d'attaque

À exécuter après le reboot, connecté en `MERIDIAN\Administrator`. Image en anglais : groupe `Domain Admins`.

powershell

```powershell
Import-Module ActiveDirectory
$dn = "DC=meridian,DC=local"

# Unites d'organisation
New-ADOrganizationalUnit -Name "Meridian" -Path $dn
foreach ($ou in @("Direction","IT","Finance","Services","ComptesDeService")) {
    New-ADOrganizationalUnit -Name $ou -Path "OU=Meridian,$dn"
}

# Utilisateur standard = acces initial simule
New-ADUser -Name "Jean Dupont" -SamAccountName "jdupont" `
  -UserPrincipalName "jdupont@meridian.local" -Path "OU=Finance,OU=Meridian,$dn" `
  -AccountPassword (ConvertTo-SecureString "Welcome2026!" -AsPlainText -Force) `
  -Enabled $true -PasswordNeverExpires $true

# CHEMIN PRINCIPAL : svc_sql kerberoastable (SPN + mdp faible) puis Domain Admin
New-ADUser -Name "svc_sql" -SamAccountName "svc_sql" `
  -UserPrincipalName "svc_sql@meridian.local" -Path "OU=ComptesDeService,OU=Meridian,$d
  -AccountPassword (ConvertTo-SecureString "Summer2026" -AsPlainText -Force) `
  -Enabled $true -PasswordNeverExpires $true
Set-ADUser -Identity "svc_sql" -ServicePrincipalNames @{Add="MSSQLSvc/dc01.meridian.loc
Add-ADGroupMember -Identity "Domain Admins" -Members "svc_sql"

# CHEMIN SECONDAIRE : mservice AS-REP roastable
New-ADUser -Name "mservice" -SamAccountName "mservice" `
  -UserPrincipalName "mservice@meridian.local" -Path "OU=ComptesDeService,OU=Meridian,$
  -AccountPassword (ConvertTo-SecureString "Spring2026" -AsPlainText -Force) `
  -Enabled $true -PasswordNeverExpires $true
Set-ADAccountControl -Identity "mservice" -DoesNotRequirePreAuth $true

# Partage cible (objectif d'exfiltration)
New-Item -Path "C:\FinancesConf" -ItemType Directory -Force
"RELEVE CLIENT FICTIF - Compte 00412 - Solde 1 284 000 EUR" | Out-File "C:\FinancesCon
New-SmbShare -Name "FinancesConf" -Path "C:\FinancesConf" -FullAccess "MERIDIAN\Admini
```

Faiblesses volontaires (documentées)

Élément	Faiblesse posée	Technique exploitée
`svc_sql`	SPN enregistré	Kerberoasting (T1558.003)
`svc_sql`	mot de passe faible (saison+année)	Crackage hors ligne (T1110.002)
`svc_sql`	membre de Domain Admins	Escalade (T1078.002)
`mservice`	pré-auth Kerberos désactivée	AS-REP Roasting
`FinancesConf`	lisible par Administrator seulement	Accès anormal détectable (T1039)

---

5. Vérification du montage

```powershell
Get-ADDomain | Select Name, DNSRoot, DomainMode
Get-ADUser -Filter * | Select SamAccountName
Get-ADUser svc_sql -Properties ServicePrincipalNames | Select -ExpandProperty ServicePr
Get-ADGroupMember "Domain Admins" | Select -ExpandProperty SamAccountName
(Get-ADUser mservice -Properties DoesNotRequirePreAuth).DoesNotRequirePreAuth
Get-SmbShareAccess FinancesConf
```

Attendu : domaine `meridian.local` (niveau Windows2016), 7 comptes, SPN sur svc_sql, svc_sql dans Domain Admins, `DoesNotRequirePreAuth = True` sur mservice, partage FinancesConf restreint à Administrator.

Un **snapshot** du disque est pris à ce stade (lab propre, avant attaque) :

```bash
gcloud compute disks snapshot dc01 --zone=europe-west1-b --snapshot-names=dc01-clean-ba
```

---

6. Justification du choix cloud

La configuration de référence (Windows Server 2025 x86-64 virtualisé en local) n'a pas pu être tenue :

- Portable **ARM64** : aucun Windows Server x86 natif.
- Poste **i7** : disque défaillant (démarrage de plusieurs heures).
- **Émulation QEMU x86** sur ARM : trop lente, installation d'AD DS bloquée après plusieurs heures.

Solution retenue et assumée : **DC sur VM cloud GCP** (image officielle Windows Server 2025, édition avec expérience de bureau), attaque depuis Kali local, accès restreint par pare-feu. Écart documenté, périmètre : Couche 1.

---

7. Arrêt du lab (économie du crédit cloud)

bash

```
gcloud compute instances stop dc01 --zone=europe-west1-b
```